

AI Forensic Readiness v0.2

Discussion draft for public review - September 8, 2026 Author: Dr. Stephen Coston Repository | RFC 0001 | Case synthesis

This version turns the first three investigations and the remaining seven research scenarios into a testable evidence profile. It adds explicit authority lifecycle, memory lineage, approval presentation, validation scope and evidence-quality records. The six investigation questions and the R0-R3 reversibility model remain.

This is a practitioner discussion draft. Public review remains open through **October 17, 2026** in [issue 1](#). The v0.1 release, citation and evidence bundles remain available. No new archival DOI, external reproduction, human-subject result or production validation is claimed.

1. Reading this draft

Sections 2-8 specify the proposed v0.2 evidence requirements. In these sections, **MUST** identifies a proposed conformance requirement, **SHOULD** a recommendation whose exception needs a documented reason, and **MAY** an optional capability. Sections 9-11 and all reference-case findings are informative.

The event schema tests structure. An operational assessment also tests source authority, content availability, investigation utility and controls. Passing JSON Schema validation does not establish authenticity, complete capture or safe use.

2. Required investigation outcomes

Question	Required evidence	Closure limit
Who acted, and for whom?	Human, agent, runtime and delegated identities; grant and policy references	Credential use alone does not prove a human selected the action
What context influenced the action?	Protected instruction, retrieval and memory references; material chunk IDs and versions	Exposure to a chunk does not prove cognitive causation
What was requested, allowed and completed?	Separate request, authorization and completion evidence linked by identifiers	Approval and authorization records do not prove execution
Where did inputs originate?	Source trust, transformations, digests and tenant/workflow provenance	A trusted writer does not make untrusted input trustworthy
What persisted or propagated?	Stores, derivatives, queues, tasks, grants, recipients and consumer inventory	Inventory-scoped containment does not establish global absence
What was contained or recovered?	Independent access probes, state reconciliation and residual disposition	Compensation and prospective denial do not undo disclosure

Investigators **MUST** state an unknown when required evidence is absent. A generated summary **MUST NOT** be counted as a second corroborating source for its own inputs. Private model reasoning is outside the minimum evidence profile.

3. Versioned event envelope

The [v0.2 schema](#) is a separate schema with `schema_version: 0.2.0-draft`. Existing v0.1 events remain v0.1; changing their version string does not constitute migration.

All v0.2 events **MUST** include stable event, trace and session identifiers, a timezone-qualified timestamp, agent/runtime identity, collection and retention metadata, one or more evidence references, and a capture-quality assessment. Identifiers need not be W3C trace identifiers. Exporters **MUST** retain that distinction.

Field group	Added evidence	Why it is needed
evidence_refs	Protected source-record references	Makes the support for a normalized event inspectable
evidence_quality	Capture status, confidence, missing sources, limitations; optional sampling/clock uncertainty	Prevents an evidence gap from becoming an asserted fact
decision	Consequence, reversibility at authorization, rule, evaluated inputs and reason	Records the basis and consequence of granting authority
influence.context_chunks	Chunk ID, source reference, SHA-256, trust label and optional tenant	Preserves the exact material selected without requiring universal prompt storage
memory	Source/writer, transformations, derivative IDs, trust and disposition	Tracks durable influence across sessions
delegation	Parent and child grants, lease, scopes, audiences, expiry and revocation mechanism	Separates identity from usable authority
oversight	Reviewer, decision time, displayed evidence, available actions and independence	Lets an investigator compare approval presentation with execution
validation	Method, expected/observed result, scope and validator identity/independence	Makes a containment or recovery claim testable
ai_component	Deployment/evaluation references and tool-manifest digest	Pins actions to the deployed configuration
state	Disposition and its scope	Separates deletion, restoration, compensation and unknown residuals

Tool authorization and execution events **MUST** record their operation, target, outcome, consequence, reversibility classification, policy rule and evaluated inputs. Memory, delegation, approval and state-validation events **MUST** carry their corresponding structured group. Unknown consequence or reversibility is representable; its presence **MUST NOT** be treated as a completed risk evaluation.

An event may record a control failure. For example, an authorization event can truthfully record an unsafe allow decision. Schema conformance is not a policy engine.

4. Authority lifecycle and containment

Distinct child identities are permissible and may improve attribution. The Case 003 failure is **authority lifecycle enforcement**, not the mere existence of a child credential. The lease was still within its expiry window when parent revocation failed to stop its use. Calling that lease expired would misstate the evidence.

A delegation profile **MUST** identify the parent grant, child grant, task and lease; the child subject; effective scopes and audiences; expiry; and the revocation mechanism. A parent session identifier alone is insufficient if it cannot resolve to the authority being revoked.

For a parent-bound grant, usable child authority **MUST** be limited by both its own lifetime and the parent's effective grant lifetime. Resource authorization **MUST** check revocation, audience and scope at use. Distinct credential issuance does not remove this dependency. A cascade implementation **SHOULD** preserve fan-out receipts, failed revocations and the interval before every descendant enforcement point denies use.

An intentionally independent grant **MUST** be explicit in the delegation policy and containment inventory. Its continued use after parent isolation must be evaluated against that policy, not silently presented as recursive revocation.

Responders **MUST** inventory known sessions, grants, leases, child runtimes, queued and scheduled tasks, service-principal bindings, tools and downstream state. Containment results **MUST** identify the inventory authority and limits. A passing parent denial probe does not establish descendant denial.

The [Case 003 review response](#) links the original records and the supplemental parent-bound comparison. The local grant tests cover own expiry, parent expiry, parent revocation, own revocation, audience and scope. They do not test a live identity provider or token cache.

5. Influence, persistent state and revocation

Material context **SHOULD** preserve stable chunk IDs, source versions/digests, selection time, trust and access boundary. A source reference **MUST** be resolvable by an authorized investigator or explicitly marked unavailable. A digest without the corresponding protected content can verify a later candidate; it cannot reconstruct missing content by itself.

Memory events **MUST** retain source and derived-state trust separately. Derived trust **MUST NOT** be upgraded solely because an approved agent wrote the memory. Record writes, reads, transformations, derivative identifiers, consumer scope and disposition. A source deletion **MUST** trigger investigation of surviving summaries, embeddings, caches and consumers; it does not itself prove their removal.

Revocation reports **MUST** separately state:

1. Prospective access: which grants and enforcement points were tested, when, with what expected and observed decisions.
2. Retrospective disposition: what operational derivatives and recipient copies were deleted, quarantined, retained or remain unknown.
3. Protected evidence: what is retained outside operational access, by whom and under what retention/access rule.

Operational deletion is compatible with justified protected evidence retention. Neither proves deletion from unknown backups or external recipients.

6. Meaningful approval and configuration evidence

For consequential approvals, implementations **MUST** preserve the reviewer, decision time, material evidence actually presented and available actions. They **SHOULD** bind that presentation to the exact operation, target and arguments digest. Record the ability to reject or escalate and whether the presentation shares a potentially compromised source with the agent recommendation.

Elapsed review time alone does not prove thoughtful review. The evidence may support conclusions about presentation or authority while leaving attention, competence and subjective judgment unknown. Case 006 uses a scripted reviewer and provides no empirical claim about human behavior.

Deployments **SHOULD** preserve immutable model, prompt, policy and tool versions, capability-description digests and the evaluation baseline used for admission. Record both evaluated and deployed configurations. Version drift can establish that configuration changed without proving which component caused a behavior change.

7. Recovery, evidence integrity and uncertainty

The existing reversibility classes remain: R0 has no persistent state change; R1 has a direct restoration path; R2 requires a compensating action; R3 cannot restore the relevant prior state. These classes **MUST** be evaluated against the consequence in question. Deleting a local publication does not restore confidentiality when a recipient retains a copy.

Recovery records **MUST** distinguish the intended state, observed state, validation method, validator, scope and residual effects. Production validation **SHOULD** use a separate authority from the affected agent. The simulations explicitly use `simulation_only` independence, because all their source records share one program.

Collectors **MUST** record sampling, collection failures and material clock limits where those affect reconstruction. Incomplete coverage **MUST NOT** support a universal negative claim. The repository orders its deterministic fixtures; real distributed systems require causal references and clock uncertainty rather than timestamp order alone.

Evidence exports **MUST** bind each artifact to its path, source, collection time and digest. Verify coverage, references and hashes before analysis. SHA-256 manifests detect changes relative to a trusted manifest; an attacker who can rewrite both the data and manifest can defeat that check. Independently protected manifests, retention controls and trusted signatures remain deployment responsibilities.

8. Privacy and operational conformance

Collect content in proportion to consequence. Prefer protected references and selective snapshots over copying entire prompts, responses or mailboxes into every telemetry destination. Apply authorization, minimization, retention and redaction to the envelope as well as its referenced evidence. Identifiers, targets and digests may themselves reveal sensitive information.

An assessor **MUST** distinguish structural conformance from deployment readiness. Use the [assessment](#) with concrete exercise results and retain unresolved limitations. Overall maturity is bounded by the lowest required capability; do not average away a consequential weakness.

9. Reference implementation and compatibility

Cases 001-003 retain their original v0.1 bundles. Cases 004-010 have complete deterministic failure/control bundles. Supplemental simulations for 001-003 test the same control relationships, rather than replaying the historical fixture times. All twenty conditions run locally without models, credentials or external actions.

The [mapping specification](#) provides OCSF 1.6.0 and OpenTelemetry Logs Data Model projections. AI-specific fields remain in an explicitly identified extension or body. No official extension, certified compatibility, live collector acceptance or loss-free field-level interoperability is claimed.

Migration requires preserving the original v0.1 event, resolving available evidence, and populating the additional v0.2 fields with supported values or explicit unknowns. Do not fabricate absent approval, grant or content evidence to satisfy a profile.

10. Reproducible checks

```
python -m pip install -r requirements.txt
python scripts/validate.py
python scripts/build_cases.py --check
python -m unittest discover -s tests -v
```

These checks cover positive/negative schema conformance, all manifests, event and record references, graph support, deterministic regeneration, controlled state transitions and mapping preservation. They do not measure independent investigator performance or production control effectiveness.

11. Review and release disposition

RFC 0001 records evidence and compatibility decisions. The [review kit](#) supplies focused questions and a blind-exercise form. [Publication status](#) separates completed repository work from external review, administrative settings and archival work.

License: prose and diagrams CC BY 4.0; schemas and code Apache-2.0. Cite the archived v0.1 DOI only for that release. For this unarchived draft, identify the Git commit and file path until a new version DOI is actually assigned.